Portada

SGSIREG006 · Versión 1.11 · Borrador · Aprobación pendiente

Vista de lectura del libro Excel, con sus hojas, campos y valores calculados. Escenario ficticio. Revisión iniciada el 27/09/2026; edición de lectura del 28/09/2026. El historial se conserva y no acredita operación ni aprobación.

SGSI-REG-006 — Registro de No Conformidades, Deuda de Diseño y Acciones Correctivas

Organización: Atalaya Gestión Patrimonial SL

Código de documento · SGSI-REG-006

Versión · 1.11

Estado · Borrador — revisión documental pendiente de aprobación

Clasificación · Confidencial

Propietario · Dirección General — Atalaya GP SL

Autor · El consultor (externo)

Emisión v1.0 · 24/07/2026

Revisiones v1.1 a v1.7 · 24/07/2026, 20/08/2026 y 22/08/2026

Revisión v1.8 · 23/08/2026

Aprobación revisión 1.11 · Pendiente conforme a DOC-002 §4; sin acta de aprobación de esta revisión

Objeto

Registro previsto en SGSI-DOC-010 §4. Recoge los incumplimientos de requisitos del SGSI, su análisis de causa y las acciones correctivas asociadas, con su verificación de eficacia (cláusula 10.2).

Dos hojas y por qué están separadas

«No conformidades» registra incumplimientos de requisitos exigibles, también durante la implantación. «Deuda de diseño» conserva las acciones aún pendientes y su trazabilidad. La ausencia de auditoría no excluye una no conformidad. HD-08 se vincula al incumplimiento documental identificado en la revisión; no se simula una auditoría ni una ejecución.

Reglas de uso

1. Una acción sin verificación de eficacia no cierra la no conformidad: la esconde. El campo de verificación es obligatorio.

2. El análisis de causa pregunta qué del sistema permitió el fallo, no quién falló (regla de no represalia, DOC-003).

3. Si la causa apunta a un escenario mal valorado, obliga a re-evaluarlo (DOC-004 §8) y a registrarlo en la columna correspondiente.

4. Primero se contiene el efecto, después se analiza la causa.

La clasificación depende de la exigibilidad del requisito. El vencimiento de un plazo obliga a revisar el incumplimiento, pero no aplaza obligaciones ya aplicables. No se cierra una acción sin verificar su eficacia.

Historial de versiones

Versión · Fecha · Descripción del cambio

1.6 · 20/08/2026 · Alta de la entrada HD-08 en esta hoja (el MSP opera como encargado del tratamiento de facto sin contrato conforme al art. 28 RGPD), reflejada también en SGSI-DOC-010 v1.9 §4.1. Hallazgo identificado al construir SGSI-REG-008, tratamiento T-10.

1.7 · 22/08/2026 · Ampliación del alcance de HD-01, que pasa de doce a trece controles con el alta de A 8.21, retirado de su anexo de soporte contractual en SGSI-DOC-006 v1.5.

1.8 · 23/08/2026 · HD-08: se anota el alta del borrador SGSI-ACU-003 v0.1 (anexo de encargado del tratamiento con el MSP, art. 28 RGPD), redactado el 23/08/2026 y pendiente de aprobación del Comité y de firma por el MSP. El hallazgo NO se cierra: conforme a la regla de uso 1 de esta misma hoja («una acción sin verificación de eficacia no cierra la no conformidad, la esconde») y a DOC-010 §4, el borrador no es la acción determinada —formalizar el contrato— sino su preparación. Estado permanece Abierta; plazo sin cambios (20/11/2026). Sin otras altas, bajas ni cierres de hallazgos.

Historial completo v1.0-1.5 en SGSI-REG-006 v1.7 (sin cambios respecto de esa versión).

Revisión de septiembre: NC-2026-001 vinculada a HD-08; altas HD-09 y HD-10. Todas abiertas, sin evidencia de eficacia. No cambian la fecha de corte ni los cierres históricos.

Historial 1.9 | 20/09/2026 | Autor del caso | Corrección de coherencia y legibilidad. Deltas en correcciones_2026-09.md. Sin aprobación formal ni eficacia operativa declarada.

Historial 1.11 | 27/09/2026 | Autor del caso | Revisión por dominios aplicables. Estado Borrador; aprobación pendiente. Corte operativo 24/07/2026 conservado; no acredita implantación ni eficacia. Ver revisión 2026-09-27.

HD-11 sustituye la formulación de la propuesta adjunta, aún no publicada, que exigía físico en RSC-007/RSC-024. No declara cerrados los pendientes operativos. HD-02/HD-03: vencimientos históricos pendientes de decisión al 27/09/2026, sin alterar el corte operativo.

No conformidades

NC-2027-001 (ejemplo)

Origen: Revisión de registros · **Clasificación:** Menor

Descripción del incumplimiento: Ejemplo de formato. Sustitúyase por una no conformidad real.

Requisito incumplido: Cláusula o control del Anexo A

Reacción inmediata: Qué se hizo para contener el efecto antes de analizar la causa.

Análisis de causa: Qué del sistema permitió el fallo. No quién falló.

Acción correctiva: Acción dirigida a la causa, no al síntoma. · **Responsable:** Rol responsable · **Plazo:** dd/mm/aaaa

Verificación de eficacia: Cómo se comprueba que la acción funcionó, vencido el plazo.

Fecha verificación: dd/mm/aaaa · **Estado:** Abierta · **¿Obliga a re-evaluar escenario?:** — · **HD de origen:** —

NC-2026-001 — 20/09/2026

Origen: Revisión documental del caso ficticio · **Clasificación:** Incumplimiento documental

Descripción del incumplimiento: HD-08 describe acceso del MSP a datos sin contrato de encargo.

Requisito incumplido: RGPD art. 28; A.5.20/A.5.31/A.5.34

Reacción inmediata: Reconocer la carencia y mantener la acción abierta; no presentar el borrador como contrato.

Análisis de causa: La revisión contractual no identificó la relación de encargo antes del acceso descrito.

Acción correctiva: Formalizar encargo y verificar obligaciones, región de alojamiento y eficacia.

Responsable: Dirección General · **Plazo:** 20/11/2026

Verificación de eficacia: Pendiente de ejecución y verificación; no se declara eficacia.

Fecha verificación: — · **Estado:** Abierta

¿Obliga a re-evaluar escenario?: Revisar riesgos de acceso y privacidad sin alterar valoraciones por esta anotación.

HD de origen: HD-08

Deuda de diseño

HD-01 — 24/07/2026

Hallazgo: Trece controles del Anexo A declarados aplicables descansan en una práctica no escrita, sin documento del SGSI ni control del registro que los soporte: A 5.6, 5.29, 5.32, 6.1, 6.2, 7.5, 7.11, 8.6, 8.7, 8.12, 8.19, 8.21 y 8.23.

Origen del hallazgo: Trazabilidad de la Declaración de Aplicabilidad (SGSI-REG-003, columna «Controles»).

Tratamiento comprometido: Asignar a cada uno un documento o un control del registro, o reclasificar su aplicabilidad con justificación escrita.

Responsable: Responsable del SGSI · **Plazo:** 24/10/2026 · **Estado:** Abierta · **Fecha de cierre:** —

Si vence sin cierre: Alta como no conformidad menor por incumplimiento de la cláusula 8.1: los controles están determinados, justificados y con su estado declarado en la Declaración de Aplicabilidad, que es lo que exige 6.1.3 d); lo que falta es implementar las acciones determinadas.

HD-02 — 24/07/2026

Hallazgo: HD-02: revisar RSC-004 y RSC-016 con dominios justificados. RSC-004 mantiene ambos; RSC-016 es digital y C-020 es organizativo. La carencia física de RSC-016 no se exige en la regla revisada.

Origen del hallazgo: Verificación de la regla de convergencia sobre el registro v1.1.

Tratamiento comprometido: Revalidar tratamientos de RSC-004 y RSC-016 y el residual de PT-04/PT-06. No cerrar por cambio de metodología. Plazo histórico 24/09/2026 superado al revisar; decisión de tratamiento del vencimiento pendiente.

Responsable: Propietarios de los riesgos · **Plazo:** 24/09/2026 · **Estado:** Abierta · **Fecha de cierre:** —

Si vence sin cierre: Alta como no conformidad menor por incumplimiento de la metodología aprobada.

HD-03 — 24/07/2026

Hallazgo: Existen controles físicos contratados y operativos cuya ejecución no deja evidencia registrada, por lo que su eficacia no es verificable (RSC-018).

Origen del hallazgo: Aportación del jefe de seguridad en la revisión del catálogo de escenarios.

Tratamiento comprometido: Implantar los registros de ejecución previstos en PT-11 y medir su cumplimiento mediante el objetivo O8 (DOC-005). Revisión 27/09/2026: plazo histórico superado; no consta ejecución ni decisión sobre el vencimiento. Pendiente evaluar la consecuencia prevista, sin inventar acta ni cierre.

Responsable: Jefe de seguridad · **Plazo:** 24/09/2026 · **Estado:** Abierta · **Fecha de cierre:** —

Si vence sin cierre: Alta como no conformidad mayor: afecta a controles de riesgos de nivel Crítico.

HD-04 — 24/07/2026

Hallazgo: Cinco escenarios del registro no se situaban en ninguna interfaz declarada del alcance, incumpliendo la regla de completitud de SGSI-DOC-004 §5.1.

Origen del hallazgo: Verificación cruzada entre SGSI-REG-001 y SGSI-DOC-001 §7.4.

Tratamiento comprometido: Corregido en dos pasos: alta de cuatro interfaces en SGSI-DOC-001 §7.4 y normalización de la columna «Interfaz» de SGSI-REG-001 al vocabulario de las diez interfaces declaradas.

Responsable: Responsable del SGSI · **Plazo:** 30/09/2026 · **Estado:** Cerrada · **Fecha de cierre:** 24/07/2026 · **Si vence sin cierre:** No procede: hallazgo cerrado.

HD-05 — 24/07/2026

Hallazgo: Cuatro escenarios carecían de objetivo de seguridad asociado, dos de ellos desde la primera versión del cuadro de objetivos.

Origen del hallazgo: Verificación cruzada entre SGSI-REG-001 y SGSI-DOC-005.

Tratamiento comprometido: Corregido en la propia revisión mediante el alta de los objetivos O11 y O12 en SGSI-DOC-005.

Responsable: Comité de Seguridad Convergente · **Plazo:** 30/09/2026 · **Estado:** Cerrada · **Fecha de cierre:** 24/07/2026 · **Si vence sin cierre:** No procede: hallazgo cerrado.

HD-06 — 24/07/2026

Hallazgo: HD-06: comprobación automática de estados SoA-registro incorporada; compara identificadores, vocabulario, soporte y excepciones explícitas.

Origen del hallazgo: Verificación cruzada entre SGSI-REG-003 y SGSI-REG-001 (hoja «Controles»).

Tratamiento comprometido: Implementación técnica verificable mediante check_corpus.py y pruebas. Mantener abierta hasta revisión y aceptación del resultado documental; no acredita eficacia operativa.

Responsable: Responsable del SGSI · **Plazo:** 24/10/2026 · **Estado:** Abierta · **Fecha de cierre:** —

Si vence sin cierre: Alta como no conformidad menor: la comprobación automática de coherencia seguiría sin existir.

HD-07 — 20/08/2026

Hallazgo: La clasificación de SGSI-REG-001 (Confidencial) no era coherente con su propio contenido: la portada declara «la relación completa de vulnerabilidades del sistema de protección de la familia», definición literal de Restringida en SGSI-DOC-002 §5. El mismo desajuste afectaba a esta hoja y a SGSI-DOC-010 §4.1.

Origen del hallazgo: Revisión de clasificación de agosto de 2026, por aplicación de la regla del nivel superior de SGSI-DOC-002 §5.

Tratamiento comprometido: Reclasificado SGSI-REG-001 a Restringida y SGSI-REG-006 y SGSI-DOC-010 a Confidencial, en esta misma revisión.

Responsable: Responsable del SGSI · **Plazo:** 20/08/2026 · **Estado:** Cerrada · **Fecha de cierre:** 20/08/2026 · **Si vence sin cierre:** No procede: hallazgo cerrado.

HD-08 — 20/08/2026

Hallazgo: El MSP tiene acceso administrativo a datos sin contrato de encargo conforme al art. 28 RGPD. La falta actual se reconoce dentro del escenario ficticio. El borrador pasa a SGSI-ACU-004 v0.2 para resolver la colisión con el acuerdo de confidencialidad de la representante. No está aprobado ni firmado. Región de alojamiento y eficacia pendientes.

Origen del hallazgo: Construcción de SGSI-REG-008 (Registro de Actividades de Tratamiento), tratamiento T-10.

Tratamiento comprometido: Formalizar SGSI-ACU-004 mediante revisión de Dirección General y asesoría legal, aprobación por Dirección General y firma bilateral. Verificar alojamiento y obligaciones efectivamente cumplidas. Vinculado a NC-2026-001.

Responsable: Dirección General · **Plazo:** 20/11/2026 · **Estado:** Abierta · **Fecha de cierre:** —

Si vence sin cierre: NC-2026-001 documenta la carencia ya identificada; el plazo 20/11/2026 es de tratamiento, no una exención del art. 28.

HD-09 — 20/09/2026

Hallazgo: HD-09: C-039/C-044 permanecen ORGANIZATIVO. RSC-019 es físico; RSC-020 mantiene ambos por la cadena declarada.

Origen del hallazgo: Revisión documental de septiembre

Tratamiento comprometido: RSC-019 deja de exigir digital por cambio justificado de aplicabilidad; RSC-020 conserva pendiente la cobertura digital. Revalidar PT-12/PT-13 y residual antes de operación. No cierre automático.

Responsable: Dirección General · **Plazo:** Antes de operación del tratamiento afectado · **Estado:** Abierta · **Fecha de cierre:** —

Si vence sin cierre: Evaluar según requisito y exigibilidad; no convertir el plazo en exención.

HD-10 — 20/09/2026

Hallazgo: Justificación residual de EIPD y precisiones RAT, plazos laborales, geolocalización y roles de proveedores pendientes.

Origen del hallazgo: Revisión documental de septiembre

Tratamiento comprometido: Validar cada finalidad y base, medidas y residual antes de operación; decidir consulta previa según art. 36. No declarar consulta ni mitigación ya realizadas.

Responsable: Dirección General · **Plazo:** Antes de operación del tratamiento afectado · **Estado:** Abierta · **Fecha de cierre:** —

Si vence sin cierre: Evaluar según requisito y exigibilidad; no convertir el plazo en exención.

HD-11 — 27/09/2026

Hallazgo: Revisión de dominios y alcance: RSC-014 pendiente de concretar coacción; C-016/C-019 sin mecanismo digital acreditado; C-062 es organizativo. La propuesta de exigir físico a RSC-007/RSC-024 queda sustituida por su justificación digital.

Origen del hallazgo: Revisión del registro y de la propuesta externa de 27/09/2026.

Tratamiento comprometido: Resolver las justificaciones pendientes y revisar PT-06. No añadir sistemas o controles solo para satisfacer etiquetas. No cerrar por el resultado simulado.

Responsable: Propietarios de los riesgos afectados · **Plazo:** 27/11/2026 · **Estado:** Abierta · **Fecha de cierre:** —

Si vence sin cierre: Evaluar el requisito incumplido y su exigibilidad; revisión de diseño no acredita eficacia.